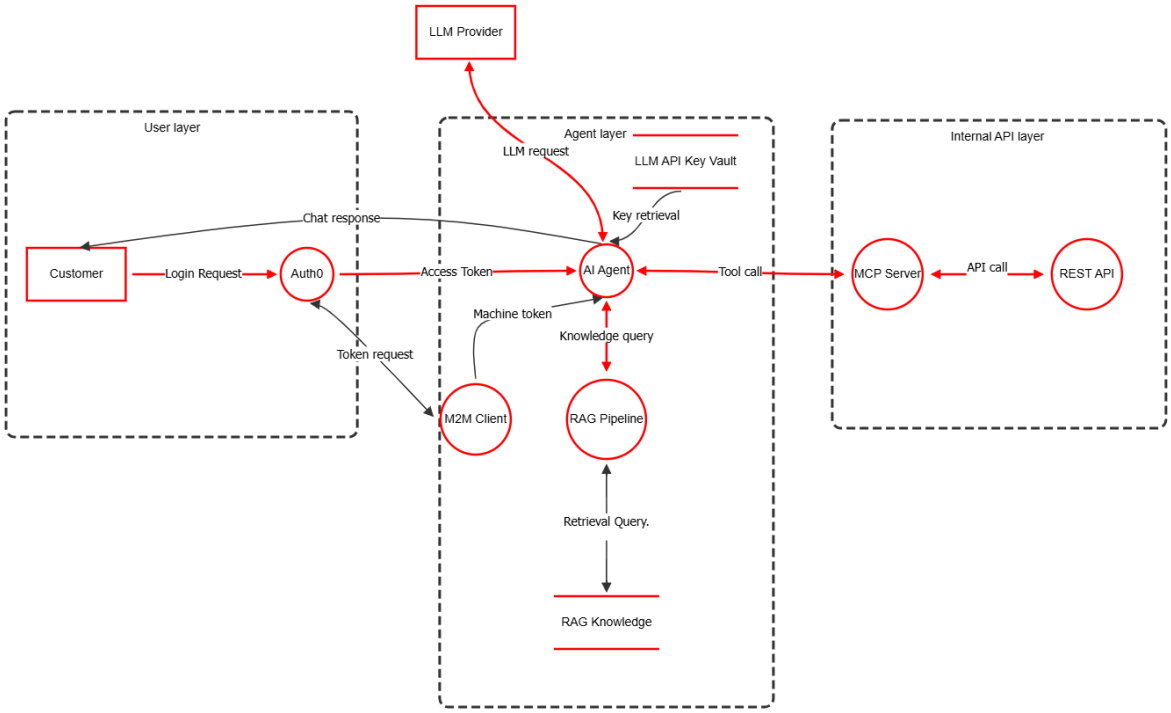
Project 1: Threat Model the AI Identity System

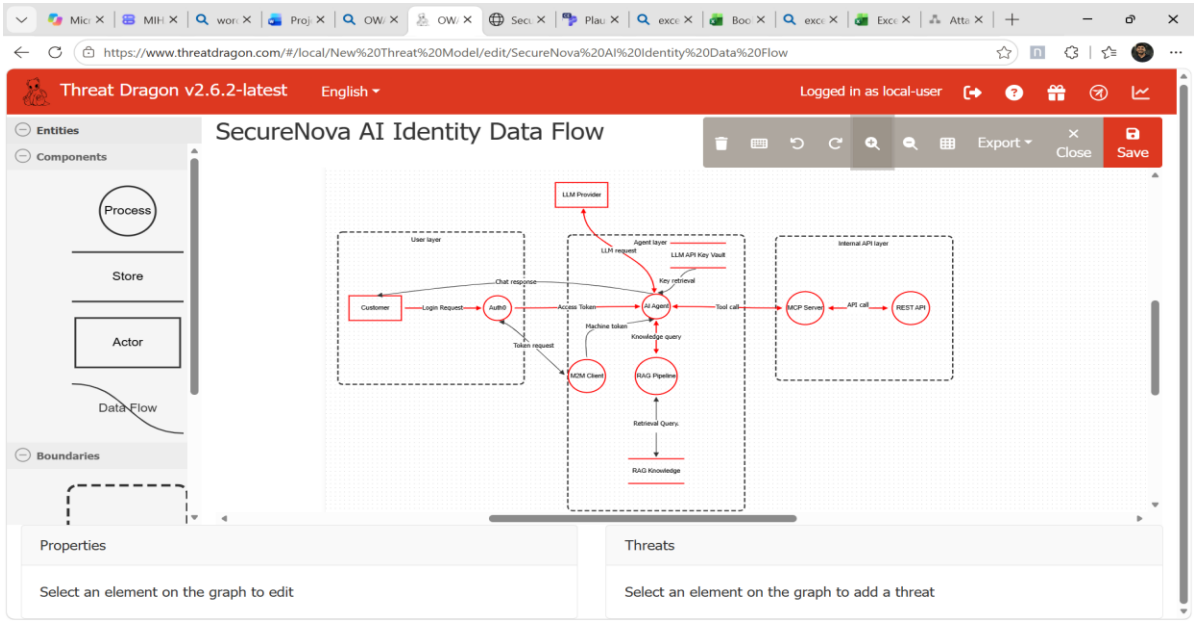
1. Identity Inventory

Identity	Authentication Mechanism	Privilege Level
Human user	Logs in through the Auth0 login page. Uses the Authorization Code flow with PKCE, plus a one-time code from an authenticator app (MFA).	Low. Can only read their own data (scope: read:ai-data). Admin users also get write:admin.
AI agent	Gets an access token from Auth0 when a user logs in and uses it to call the APIs for that user. The token carries a custom agent_id claim so we know which agent made the call.	Medium. Has the same scopes as the user it is working for, nothing extra.
OAuth M2M client	Uses the Client Credentials flow. It sends its client ID and client secret to Auth0 and gets back a short-lived token .	Medium. Can only call the APIs it has been given scopes for, such as the /chat endpoint.
LLM API key	A static secret key sent with every request to the LLM provider. It does not expire unless someone rotates it manually.	High. Gives full access to the model and its billing. It is not limited per user.
RAG pipeline service identity	A service account credential used to connect to the vector database and knowledge store.	Medium. Can read the knowledge base. Write access is only needed when new documents are added.
MCP server identity	A client credential or token used to call the internal REST APIs and run tool actions.	High. Can perform real actions such as issuing refunds or changing records, so it needs strict limits.

2. **Data-Flow Diagram**

The SecureNova identity data flow modeled in OWASP Threat Dragon. Three trust boundaries separate the User layer, the Agent layer, and the Internal API layer.

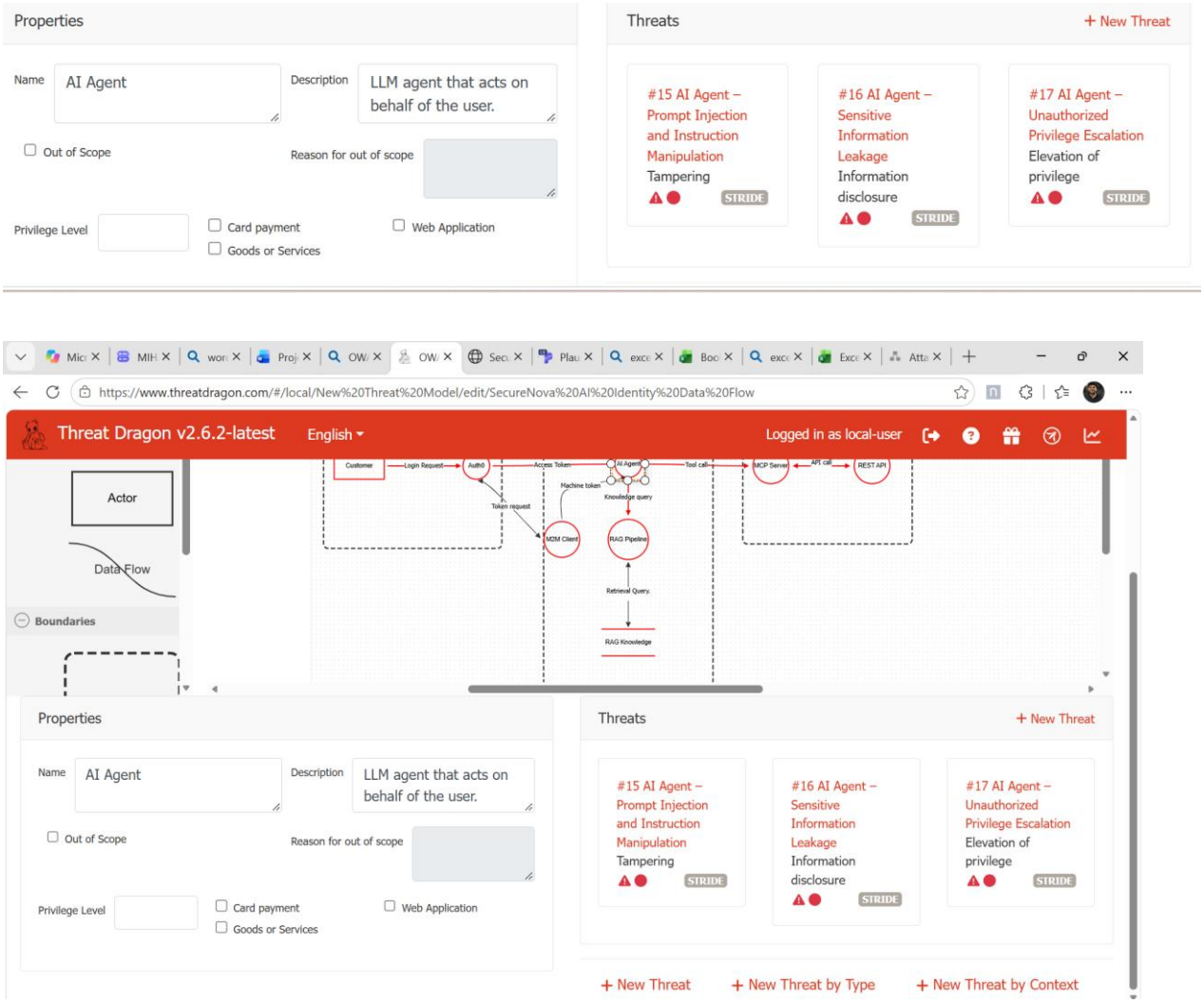




Screen shot 1.Threat Dragon data-flow diagram with identities and trust boundaries

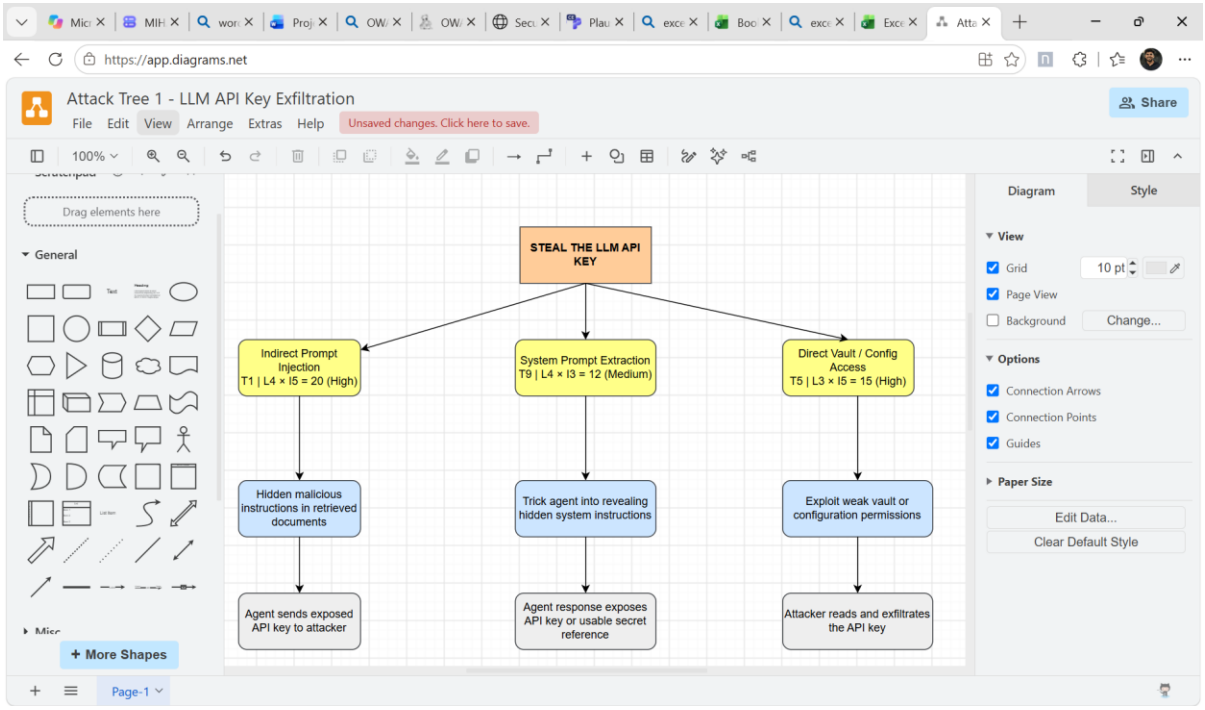
2.1 STRIDE Threats on an Identity Flow:

Threats recorded on the AI Agent flow in Threat Dragon, covering several STRIDE categories (Tampering, Information disclosure, Elevation of privilege).

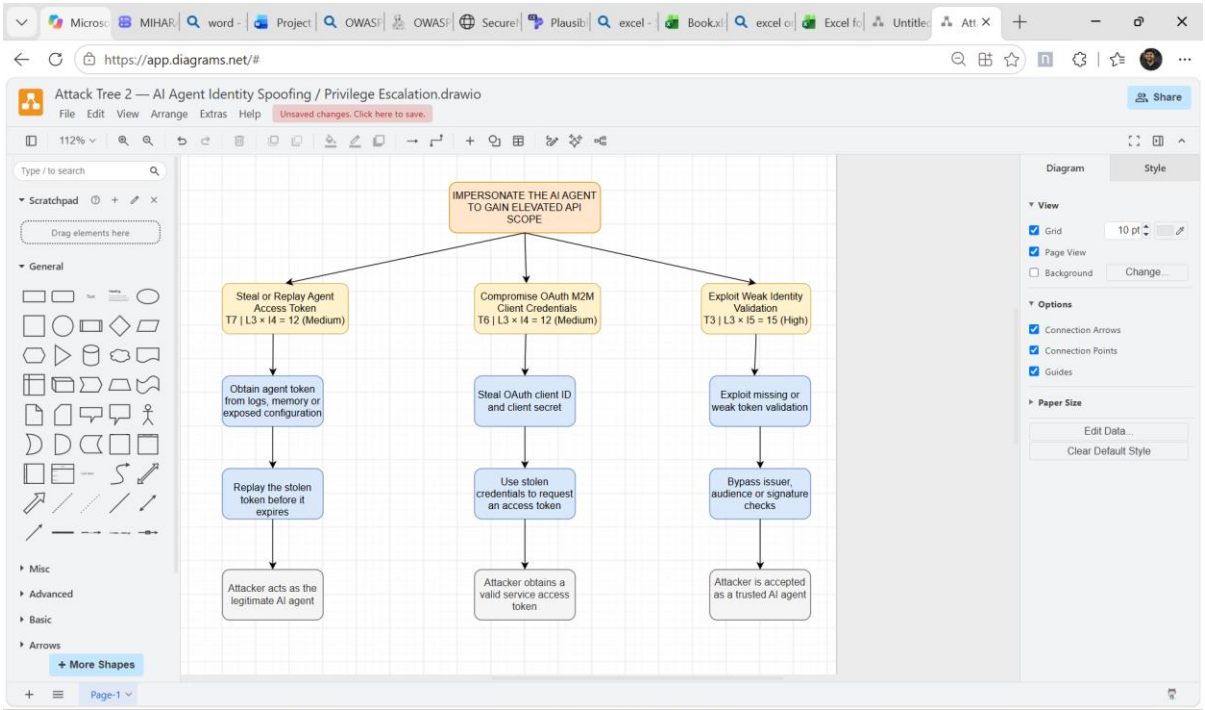


Screenshot 2: Threat Dragon threat panel showing STRIDE threats on the AI Agent

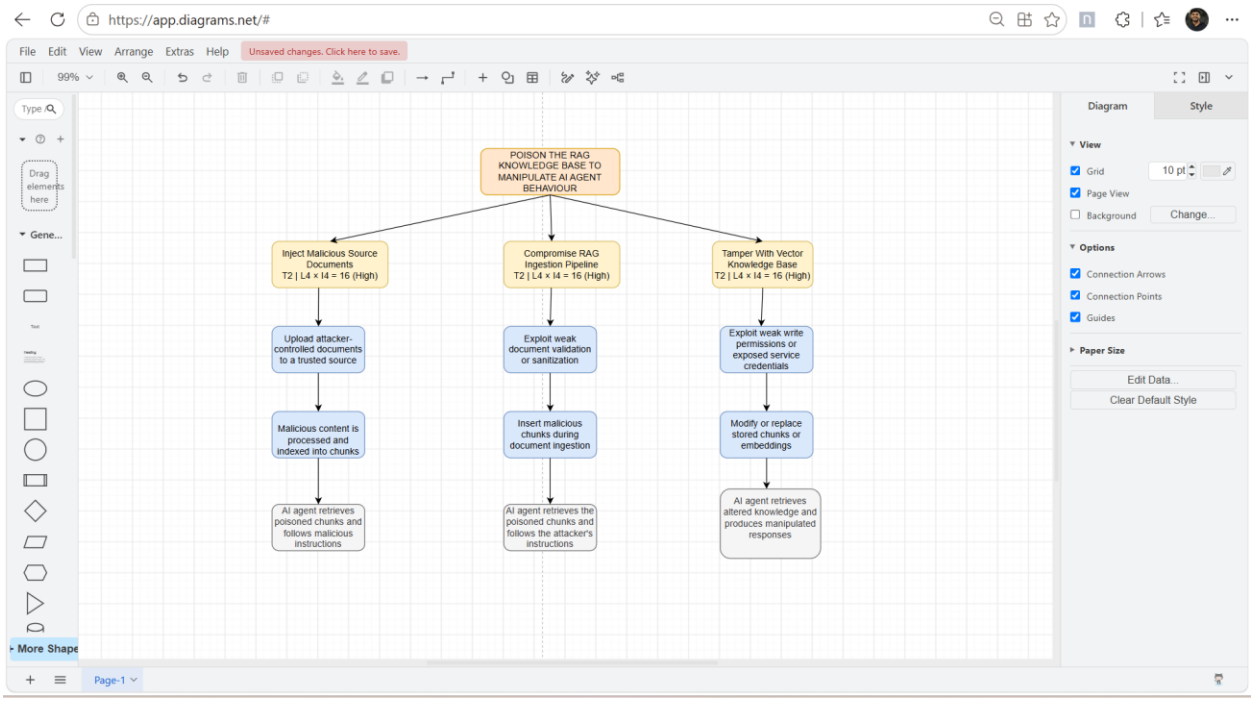
3. **Attack Trees:** Three attack trees (draw.io) model how an attacker could reach three goals against the AI identity layer. Each leaf threat is scored Likelihood x Impact = Risk Score.



Screenshot 3 — Attack Tree 1: LLM API key exfiltration via prompt injection.

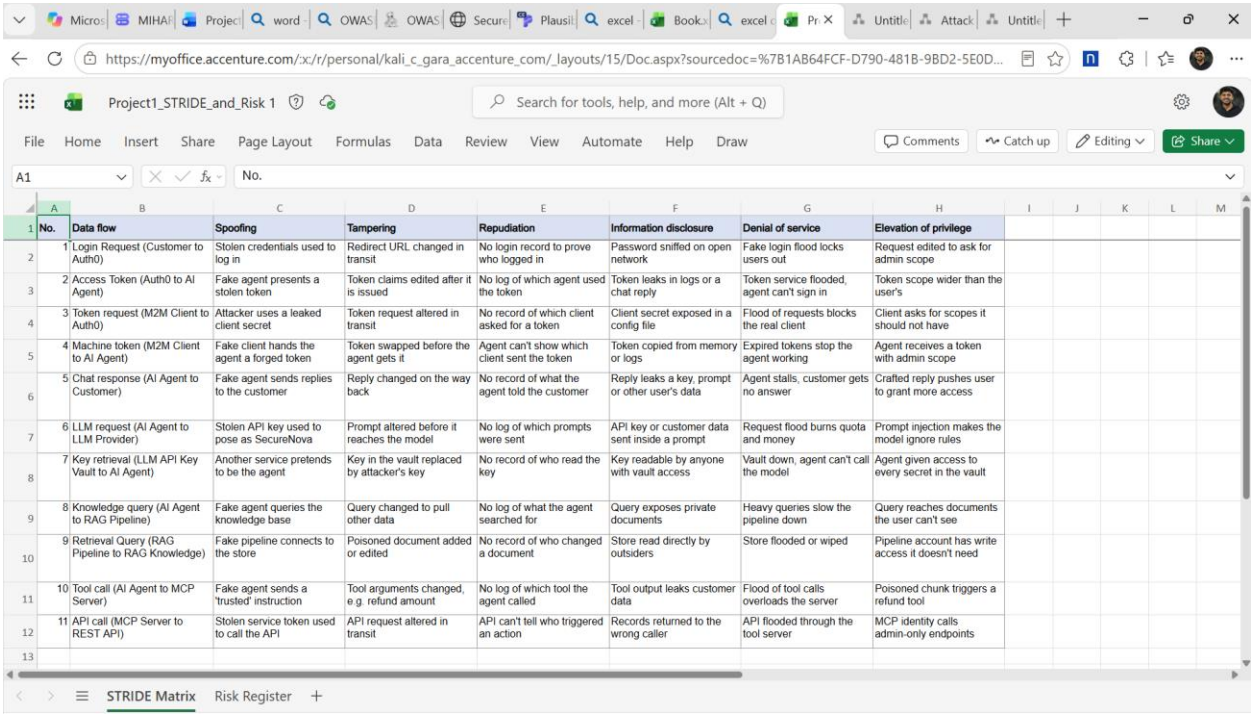


Screenshot 4 — Attack Tree 2: Agent identity spoofing to gain elevated API scope.



Screenshot 5 — Attack Tree 3: RAG chunk poisoning to manipulate agent behaviour.

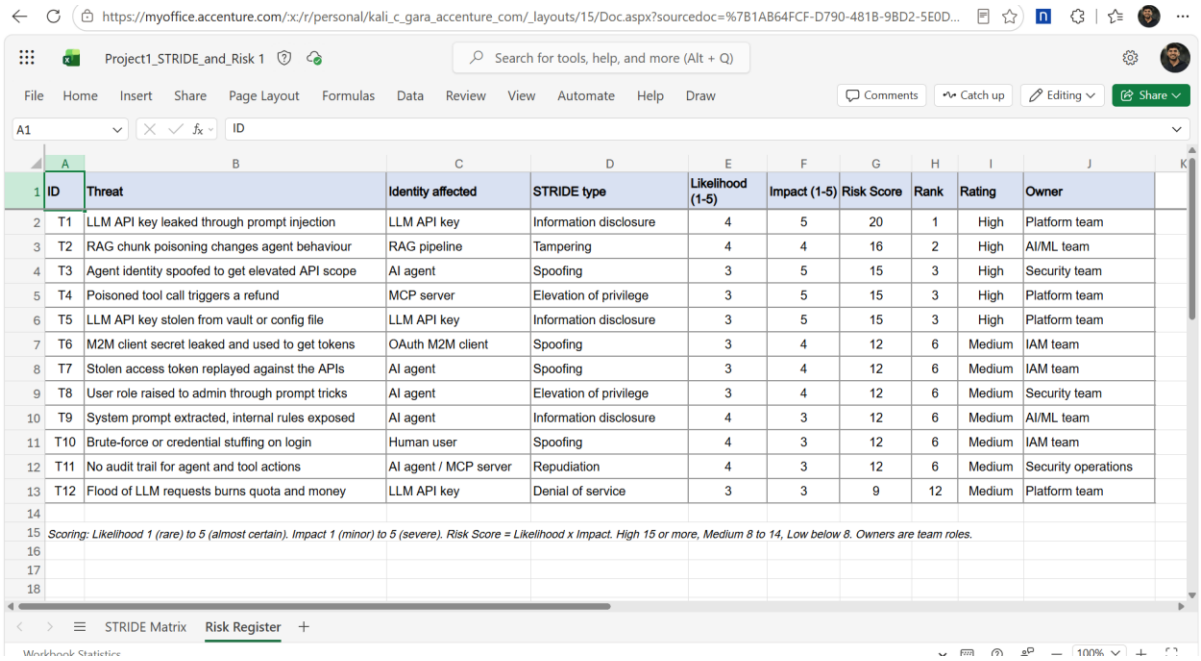
4. **STRIDE Threat Matrix :** All six STRIDE categories (Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege) applied to every data flow in the SecureNova platform.



No.	Data flow	Spoofing	Tampering	Repudiation	Information disclosure	Denial of service	Elevation of privilege
1	Login Request (Customer to Auth0)	Stolen credentials used to log in	Redirect URL changed in transit	No login record to prove who logged in	Password sniffed on open network	Fake login flood locks users out	Request edited to ask for admin scope
2	Access Token (Auth0 to AI Agent)	Fake agent presents a stolen token	Token claims edited after it is issued	No log of which agent used the token	Token leaks in logs or a chat reply	Token service flooded, agent can't sign in	Token scope wider than the user's
3	Token request (M2M Client to Auth0)	Attacker uses a leaked client secret	Token request altered in transit	No record of which client asked for a token	Client secret exposed in a config file	Flood of requests blocks the real client	Client asks for scopes it should not have
4	Machine token (M2M Client to AI Agent)	Fake client hands the agent a forged token	Token swapped before the agent gets it	Agent can't show which client sent the token	Token copied from memory or logs	Expired tokens stop the agent working	Agent receives a token with admin scope
5	Chat response (AI Agent to Customer)	Fake agent sends replies to the customer	Reply changed on the way back	No record of what the agent told the customer	Reply leaks a key, prompt or other user's data	Agent stalls, customer gets no answer	Crafted reply pushes user to grant more access
6	LLM request (AI Agent to LLM Provider)	Stolen API key used to pose as SecureNova	Prompt altered before it reaches the model	No log of which prompts were sent	API key or customer data sent inside a prompt	Request flood burns quota and money	Prompt injection makes the model ignore rules
7	Key retrieval (LLM API Key Vault to AI Agent)	Another service pretends to be the agent	Key in the vault replaced by attacker's key	No record of who read the key	Key readable by anyone with vault access	Vault down, agent can't call the model	Agent given access to every secret in the vault
8	Knowledge query (AI Agent to RAG Pipeline)	Fake agent queries the knowledge base	Query changed to pull other data	No log of what the agent searched for	Query exposes private documents	Heavy queries slow the pipeline down	Query reaches documents the user can't see
9	Retrieval Query (RAG Pipeline to RAG Knowledge)	Fake pipeline connects to the store	Poisoned document added or edited	No record of who changed a document	Store read directly by outsiders	Store flooded or wiped	Pipeline account has write access it doesn't need
10	Tool call (AI Agent to MCP Server)	Fake agent sends a 'trusted' instruction	Tool arguments changed, e.g. refund amount	No log of which tool the agent called	Tool output leaks customer data	Flood of tool calls overloads the server	Poisoned chunk triggers a refund tool
11	API call (MCP Server to REST API)	Stolen service token used to call the API	API request altered in transit	API can't tell who triggered an action	Records returned to the wrong caller	API flooded through the tool server	MCP identity calls admin-only endpoints

Screenshot 6 — STRIDE threat matrix with all six categories completed.

5. **Risk Register:** The main threats to the AI identity layer, each scored Likelihood x Impact, ranked by risk score, and assigned an owner.



Project1_STRIDE_and_Risk 1

ID	Threat	Identity affected	STRIDE type	Likelihood (1-5)	Impact (1-5)	Risk Score	Rank	Rating	Owner
T1	LLM API key leaked through prompt injection	LLM API key	Information disclosure	4	5	20	1	High	Platform team
T2	RAG chunk poisoning changes agent behaviour	RAG pipeline	Tampering	4	4	16	2	High	AI/ML team
T3	Agent identity spoofed to get elevated API scope	AI agent	Spoofing	3	5	15	3	High	Security team
T4	Poisoned tool call triggers a refund	MCP server	Elevation of privilege	3	5	15	3	High	Platform team
T5	LLM API key stolen from vault or config file	LLM API key	Information disclosure	3	5	15	3	High	Platform team
T6	M2M client secret leaked and used to get tokens	OAuth M2M client	Spoofing	3	4	12	6	Medium	IAM team
T7	Stolen access token replayed against the APIs	AI agent	Spoofing	3	4	12	6	Medium	IAM team
T8	User role raised to admin through prompt tricks	AI agent	Elevation of privilege	3	4	12	6	Medium	Security team
T9	System prompt extracted, internal rules exposed	AI agent	Information disclosure	4	3	12	6	Medium	AI/ML team
T10	Brute-force or credential stuffing on login	Human user	Spoofing	4	3	12	6	Medium	IAM team
T11	No audit trail for agent and tool actions	AI agent / MCP server	Repudiation	4	3	12	6	Medium	Security operations
T12	Flood of LLM requests burns quota and money	LLM API key	Denial of service	3	3	9	12	Medium	Platform team

Scoring: Likelihood 1 (rare) to 5 (almost certain). Impact 1 (minor) to 5 (severe). Risk Score = Likelihood x Impact. High 15 or more, Medium 8 to 14, Low below 8. Owners are team roles.

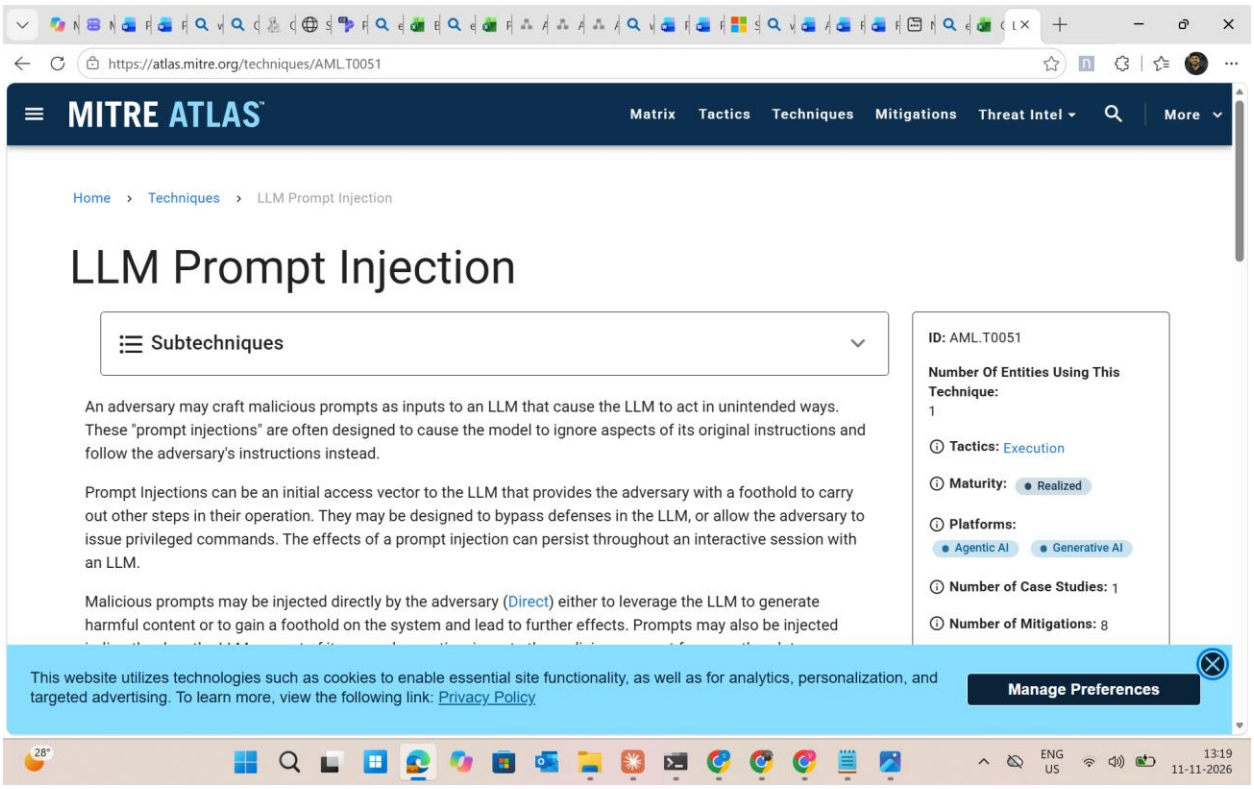
Screenshot 7 — Risk register with all threats scored and ranked by risk score.

6. **MITRE ATLAS Mapping:** MITRE ATLAS (Adversarial Threat Landscape for Artificial Intelligence Systems) is a knowledge base of adversary tactics and techniques against AI systems. Each risk is mapped to the closest ATLAS technique ID.

T1	AML.T0051	LLM Prompt Injection
T1	AML.T0056	Extract LLM System Prompt
T1	AML.T0057	LLM Data Leakage
T2	AML.T0070	RAG Poisoning
T2	AML.T0071	False RAG Entry Injection
T2	AML.T0066	Retrieval Content Crafting
T3	AML.T0073	Impersonation
T3	AML.T0012	Valid Accounts
T4	AML.T0110	AI Agent Tool Poisoning
T4	AML.T0053	AI Agent Tool Invocation
T5	AML.T0055	Unsecured Credentials
T5	AML.T0083	Credentials from AI Agent Configuration
T6	AML.T0012	Valid Accounts
T7	AML.T0091	Use Alternate Authentication Material
T8	AML.T0051	LLM Prompt Injection
T8	AML.T0054	LLM Jailbreak
T9	AML.T0056	Extract LLM System Prompt
T10	T1110 (ATT&CK)	Brute Force
T11	—	No direct ATLAS technique; audit-logging control gap
T12	AML.T0034	Cost Harvesting
T12	AML.T0029	Denial of AI Service

6.1 How the techniques apply to SecureNova

Risk ID	How the technique applies to SecureNova
T1	Malicious prompts may cause the AI agent to reveal the LLM API key or sensitive system information.
T2	Malicious or false documents may enter the RAG knowledge base and influence retrieved context.
T3	An attacker may impersonate the AI agent or abuse valid credentials to obtain unauthorized API access.
T4	A poisoned MCP tool or tool response may cause an unauthorized refund of action.
T5	Exposed vault credentials or insecure configuration may allow an attacker to obtain the LLM API key.
T6	Stolen OAuth M2M client credentials may be used to obtain valid access tokens.
T7	A stolen access token may be reused to access APIs without the legitimate agent's authorization.
T8	Prompt injection or jailbreak techniques may manipulate the agent into attempting unauthorized privileged actions.
T9	An attacker may extract the system prompt and expose internal instructions.
T10	An attacker may use repeated password guesses against human-user login.
T11	Missing audit logs may allow malicious agents or tool actions to go undetected.
T12	High-volume requests may increase service costs or overwhelm the LLM service.



Screenshot 8 — capture one of these techniques on the MITRE ATLAS website (atlas.mitre.org), e.g. AML.T0051 (LLM Prompt Injection), with the AML.T0051 ID visible.

Submitted by: Kali Charan Gara

Candidate ID: 14226839

